



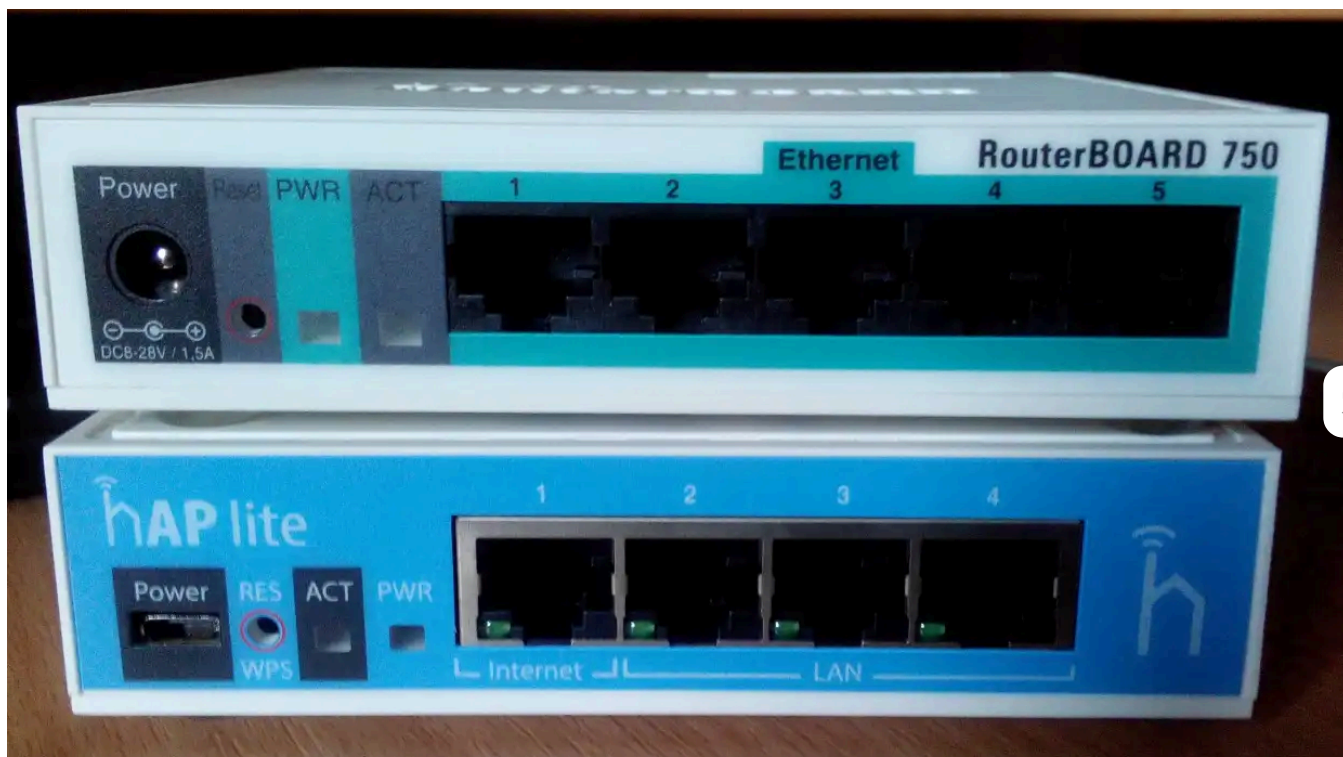
Автор: Люциан Константин
Старший писатель CSO

MikroTik исправляет уязвимости, которые в настоящее время используются для взлома маршрутизаторов

Новости

9 сентября 2026 года • 4 минуты

MikroTrick объединяет две из шести исправленных уязвимостей для получения root-доступа на устройствах MikroTik с открытым для интернета SSH, которых насчитывается более 120 000.



Источник: Stacatto / Wikimedia

Производитель сетевого оборудования MikroTik выпустил патчи для устранения шести уязвимостей в своей прошивке RouterOS, две из которых можно объединить в цепочку для получения контроля над устройствами без аутентификации по протоколу SSH. Цепочка эксплоитов, получившая название MikroTrick, уже используется злоумышленниками.

Уязвимости [<https://cert.pl/en/posts/2026/09/mikrotik-routeros-cve/>], обнаруженные исследователями из CERT Polska, находятся в различных компонентах встроенного ПО, включая SSH-сервер и клиент, службу проверки пропускной способности, код обработки сертификатов X.509 и интерфейс WebFig.

«В последние дни мы наблюдаем атаки на устройства RouterOS, доступные из интернета, — сообщила польская команда CERT в **отчёте** [<https://cert.pl/en/posts/2026/09/vulnerabilities-in-mikrotik-routeros-actively-exploited/>]. — Мы получили подтверждение того, что злоумышленники используют эту комбинацию уязвимостей для получения полного контроля над устройствами, служба SSH которых доступна из общедоступных сетей». Компания MikroTik выпустила исправления для RouterOS 7.25 beta 3, 7.24.2, 7.23.4 и 6.49.21 и не рекомендует включать службу SSH на интернет-интерфейсе. Несмотря на то, что это не конфигурация по умолчанию, более 122 500 устройств MikroTik имеют доступ к SSH из интернета **согласно результатам сканирования, проведенного Shadowserver Foundation** [<https://x.com/Shadowserver/status/2096678032744280476>], причем больше всего таких устройств в Бразилии, США и Индонезии.

Компания MikroTik, базирующаяся в Латвии, производит маршрутизаторы, коммутаторы и другие сетевые устройства для широкого круга клиентов — от малого

бизнеса до крупных предприятий. Ее продукция используется во многих отраслях, включая телекоммуникации, образование и государственное управление.

«Если вы открыли этот порт [SSH] вручную, убедитесь, что доступ к нему возможен только с доверенных IP-адресов, а еще лучше — используйте надежный VPN, например WireGuard, для доступа к маршрутизатору и вообще не открывайте никаких портов управления, — говорится в рекомендациях компании по ссылке [https://mikrotik.com/supportsec/september-2026-vulnerability]. — RouterOS проверит, не было ли ваше устройство скомпрометировано, и в случае компрометации присвоит ему статус «Помечено». Это будет указано в разделе «Журнал».»



Ошибка при проверке ключа SSH

Самая серьезная уязвимость, зарегистрированная как CVE-2026-67276, связана с некорректной проверкой открытых ключей RSA пользователей — ключевого компонента аутентификации SSH. SSH считается очень надежным и хорошо изученным протоколом, который использует криптографию с открытым ключом для проверки подлинности сервера и пользователя.

Из-за ошибки в реализации RouterOS не сравнивает весь открытый ключ, представленный пользователем. Это позволяет злоумышленнику, знающему имя пользователя и открытый модуль ключа пользователя, создать закрытый ключ, который позволит ему пройти аутентификацию от имени этого пользователя.

Полученная привилегия соответствует привилегиям целевого пользователя, однако в игру вступает вторая уязвимость (CVE-2026-86060), позволяющая повысить привилегии до уровня root. Это связано с другой ошибкой в реализации SSH при обработке имен пользователей со специальными символами в начале. Это позволяет злоумышленникам создавать имена пользователей с полными административными привилегиями в базовой операционной системе.

Смягчение последствий

Механизм Flagged state, добавленный компанией MikroTik, указывает на то, что в конфигурации маршрутизатора есть признаки несанкционированных изменений, но не сообщает, какие уязвимости использовались для их внесения. Кроме того, отсутствие этого маркера не обязательно означает, что устройство безопасно и не подвержено уязвимостям.

“We cannot rule out the existence of vulnerabilities unknown to us that the vendor did not describe in the changelog,” the CERT Polska Team said. “The ‘Flagged’ marker for compromised devices should therefore be treated as an indication of a possible earlier compromise, not as proof that one of the vulnerabilities reported by CERT Polska was exploited.”

If a device does have the Flagged marker, it should be immediately isolated, it's configuration and logs should be saved, and then it should be reset to factory defaults and reconfigured from a clean file. All keys and passwords used on the device should be rotated.

If the security updates cannot be applied immediately, users should disable or block access to the SSH, WWW/WWW-SSL, and the bandwidth-test server from untrusted networks.



“Do not initiate TLS connections from an unpatched device or use the built-in SSH clients (`/system ssh` and `/system ssh-exec`), especially when communication passes through untrusted networks or is directed at untrusted hosts,” the researchers said.

Network Security[\[https://www.networkworld.com/network-security/\]](https://www.networkworld.com/network-security/)

Security[\[https://www.networkworld.com/security/\]](https://www.networkworld.com/security/)

Vulnerabilities[\[https://www.networkworld.com/vulnerabilities/\]](https://www.networkworld.com/vulnerabilities/)

About

⌵

Policies

⌵

More

⌵

Our Network

⌵

